

T0.2 — Stripe webhook signature obligatorio

Resumen de implementacion · Fecha: 2026-05-01 · Sin merge, sin deploy. · Rama lista para revision.

Implementado y testeado. 4 archivos modificados, 449 tests verde, branch *pr/stripe-webhook-firma-obligatoria* en GitHub. Riesgo P0 cerrado a nivel codigo: el endpoint `/webhook/stripe` en backend ya no acepta payloads no firmados en produccion.

Identificadores

Item	Valor
Commit	e880192
Mensaje	fix(seguridad): STRIPE_WEBHOOK_SECRET obligatorio en produccion
Rama local	pr/stripe-webhook-firma-obligatoria
Rama remota	origin/pr/stripe-webhook-firma-obligatoria
Crear PR en GitHub	https://github.com/celestinojbm/Dona-agent/pull/new/pr/stripe-webhook-firma-obligatoria
main local	d7866eb (igual a origin/main, INTACTO)
origin/main	d7866eb (sin push de este PR a main)

Archivos tocados (exactamente los 4 autorizados)

Archivo	Cambio
agent/billing.py	+ check top-level: si <code>ENVIRONMENT=production</code> y no hay <code>STRIPE_WEBHOOK_SECRET</code> -> <code>RuntimeError</code> . Refactor de <code>verificar_firma_stripe</code> : lee env vars en cada llamada, en produccion sin secret retorna <code>None</code> (defensa en profundidad), en dev/test mantiene path permisivo con warning.
agent/main.py	+ import <code>agent.billing</code> # noqa: F401 despues de configurar <code>_logging()</code> para forzar el check al startup (aborta deploy en Render si falta el secret).
.env.example	+ bloque documental del secret antes del bloque <code>VOICE_FORWARD_NUMBER</code> . Sin valores reales.
tests/test_billing.py	<code>TestVerificarFirma</code> renombrado a <code>TestVerificarFirmaDev</code> con <code>ENVIRONMENT=development test</code> explicito. Agregado <code>TestVerificarFirmaProduction</code> con 4 tests: rechaza sin secret, rechaza firma invalida, <code>RuntimeError</code> al reload, no levanta con secret valido.

Total: 4 archivos, +139 lineas, -5 lineas.

Tests corridos

Suite	Resultado
<code>pytest tests/test_billing.py -x -q</code>	26 passed en 9 s (incluye 4 nuevos de production + 2 actualizados de dev/test)

Suite	Resultado
pytest -q (suite completa)	449 passed en 35 s, exit 0

Sin regresiones. Sin warnings nuevos relevantes. El unico ruido es el conocido de aiosqlite en teardown (preexistente, no relacionado).

Comportamiento implementado

Escenario	Antes (P0 abierto)	Ahora
Produccion sin STRIPE_WEBHOOK_SECRET	Acepta payloads sin firmar (warning) -> atacante acredita creditos forjados	RuntimeError al import -> deploy aborta. Si el modulo se carga, runtime tambien rechaza.
Produccion con secret + firma invalida	400 ya correcto	400, sin cambio
Produccion con secret + firma valida	200 ya correcto	200, sin cambio
Dev/test sin secret	Permisivo con warning	Permisivo con warning (mismo comportamiento, log mejorado)

Estado git

- **main local** en d7866eb, igual a origin/main. Intacto.
- **HEAD** en pr/stripe-webhook-firma-obligatoria con e880192.
- Sin push a main. Sin merge. Sin deploy.

Lo que NO toque (segun reglas)

- **landing/** — sin cambios.
- **landing/app/api/webhook/route.ts** — sigue como estaba (firma obligatoria por non-null assertion).
- **agent/billing.py:procesar_evento_stripe** — logica de acreditacion intacta.
- Base de datos / migraciones — no tocadas.
- Render / Vercel / secretos — sin cambios.

Proximo paso recomendado (no implemento sin OK)

- **Revisar el PR en GitHub** desde el link de la portada.
- **Antes de mergear**, confirmar una vez mas en Render que STRIPE_WEBHOOK_SECRET esta seteada (ya confirmado; este es el ultimo check).
- **Mergear** y observar Render logs en el primer deploy: si aparece 'RuntimeError [BILLING] STRIPE_WEBHOOK_SECRET no configurada en produccion', revertir inmediatamente.
- Como Stripe no apunta a este endpoint hoy, **no hay trafico real que verificar**. El cambio simplemente cierra una superficie de ataque publica para el día que se decida T1.3 (mover el webhook al backend).

Branch lista para merge. La decision queda en manos del owner.